



أهداف أمن المعلومات

الإصدار	اعتمد من	مالك الوثيقة	تاريخ آخر تحديث	دورية المراجعة	المراجعة القادمة	ملاحظات
1.0	الرئيس التنفيذي / الإدارة العليا	مدير أمن المعلومات سارة – (CISO) الحربي	20/09/2026	ربع سنوية	12/09/2026	وثيقة أهداف أمن المعلومات ضمن مشروع تطبيق ISO/IEC 27001:2022

التصنيف: داخلي

الغرض من الوثيقة: تحديد أهداف أمن المعلومات القابلة للقياس لبنك الأفاق الرقمية، بما يتوافق مع وضع البنك الحالي والمخاطر والحوادث (ISMS) والفجوات الواردة في دراسة الحالة، ودعم إنشاء وتحسين نظام إدارة أمن المعلومات.

أساس تحديد الأهداف: الحوادث السابقة، ضعف التوثيق والحوكمة، نتائج فحص الثغرات، نتائج محاكاة التصيد، مخاطر الوصول والصلاحيات، عدم مشكلات التشفير ومزامنة الوقت، متطلبات الاستمرارية والامتثال، واحتياجات الأطراف المعنية، SIEM وجود

ملاحظة: الحالة الحالية للأهداف في بداية المشروع اعتُبرت «مخطط/لم يبدأ» ما لم تدل دراسة الحالة صراحةً على تنفيذ الإجراء؛ أما الأنشطة التي كانت موجودة فعلياً فتم التعامل معها كنقطة أساس تحتاج إلى تطوير وقياس

أهداف أمن المعلومات الرئيسية ونتائجها القابلة للقياس

الهدف	النتيجة الرئيسية / الإجراء	المستهدف	المسؤول	الجدول الزمني	الحالة
1. إنشاء إطار قوي لنظام إدارة أمن المعلومات	استكمال تحديد نطاق نظام إدارة أمن المعلومات (ISMS) وتوثيقه واعتماده	100%	مدير أمن المعلومات سارة - (CISO) الحربي	الربع الأول من السنة الأولى	مخطط
1. إنشاء إطار قوي لنظام إدارة أمن المعلومات	إعداد واعتماد سياسات ISMS وإجراءات المطلوبة، مع معالجة السياسات القديمة أو غير المفصلة	100%	فريق حوكمة أمن المعلومات	الربع الأول من السنة الأولى	مخطط
1. إنشاء إطار قوي لنظام إدارة أمن المعلومات	إجراء تقييم شامل للمخاطر وربط المخاطر بالأصول والحوادث والضوابط وخطط المعالجة	100%	إدارة المخاطر بالتنسيق مع أمن المعلومات	الربع الأول من السنة الأولى	مخطط
1. إنشاء إطار قوي لنظام إدارة أمن المعلومات	إنشاء سجل مخاطر رسمي وتسجيل جميع المخاطر المحددة مع المالك وحالة المعالجة	100%	إدارة المخاطر	الربع الأول من السنة الأولى	مخطط
2. رفع الوعي بأمن المعلومات	تنفيذ برنامج توعية أمني لجميع موظفي البنك، مع التركيز على التصيد والإبلاغ عن الحوادث وحماية بيانات العملاء	100%	الموارد البشرية + أمن المعلومات	الربع الثاني من السنة الأولى	مخطط
2. رفع الوعي بأمن المعلومات	رفع نسبة إكمال التدريب الأمني إلى 90% على الأقل	≥90%	الموارد البشرية	الربع الثاني من السنة الأولى	مخطط
2. رفع الوعي بأمن المعلومات	خفض نسبة النقر على رسائل التصيد في الاختبارات الدورية من خط الأساس الحالي ورفع معدل الإبلاغ عن الرسائل المشبوهة من 8% إلى 25%	تحسن موثق في كل اختبار	فريق أمن المعلومات	ربع سنوي	مخطط
3. تعزيز الضوابط الأمنية التقنية	تطبيق المصادقة متعددة العوامل (MFA) على جميع الأنظمة الحرجة والحسابات ذات الصلاحيات العالية	100%	إدارة تقنية المعلومات + أمن المعلومات	الربع الثاني من السنة الأولى	مخطط

تعزيز الضوابط الأمنية التقنية 3.	معالجة جميع الثغرات عالية الخطورة المفتوحة، ثم وضع خطة زمنية لمعالجة الثغرات المتوسطة المتبقية.	عالية الخطورة 100%	فريق تقييم المخاطر والثغرات	الربع الثاني من السنة الأولى	جارٍ جزئياً
تعزيز الضوابط الأمنية التقنية 3.	تطبيق إدارة مركزية وأمنة للحسابات والصلاحيات المميزة، وإنهاء الممارسات اليدوية ومراجعة الصلاحيات دورياً.	من الحسابات المميزة 100%	إدارة تقنية المعلومات + أمن المعلومات	الربع الثالث من السنة الأولى	مخطط
تعزيز الضوابط الأمنية التقنية 3.	تطبيق تشفير كامل للأجهزة الطرفية والبيانات الحساسة، وضوابط أمنية لحذف المعلومات ونقلها.	للأصول 100% الحرجة المشمولة	إدارة تقنية المعلومات	الربع الثالث من السنة الأولى	مخطط
تعزيز الضوابط الأمنية التقنية 3.	توحيد مزامنة الوقت باستخدام مصدر مركزي موثوق ومعالجة الفروقات الزمنية بين الأنظمة.	من الأنظمة 100% الحرجة	إدارة البنية التحتية والشبكات	الربع الثاني من السنة الأولى	مخطط
تعزيز الضوابط الأمنية التقنية 3.	إيقاف بروتوكولات TLS القديمة ومراجعة إعدادات خدمات الشبكة والتهيئة الأمنية للأنظمة المواجهة للإنترنت.	من الأنظمة 100% المشمولة	إدارة الشبكات + أمن المعلومات	الربع الثالث من السنة الأولى	مخطط
ضمان الامتثال والاستعداد 4.	تنفيذ برنامج تدقيق ISMS داخلي لنظام مقابل متطلبات ISO/IEC 27001:2022 والضوابط ذات الصلة.	من النطاق 100%	المراجع الداخلي	الربع الثالث من السنة الأولى	مخطط
ضمان الامتثال والاستعداد 4.	إعداد وتنفيذ خطط إجراءات تصحيحية لجميع حالات عدم المطابقة المكتشفة.	من حالات عدم المطابقة 100%	ISMS فريق	الربع الثالث من السنة الأولى	مخطط
ضمان الامتثال والاستعداد 4.	إجراء مراجعة امتثال رسمية للسياسات والمعايير الأمنية، وتوثيق نتائجها وإجراءات التصعيد.	ربع سنوي	مدير أمن المعلومات	بدءاً من الربع الثالث	مخطط
ضمان الامتثال والاستعداد 4.	إجراء اختبار ومراجعة لخطة استمرارية الأعمال والتعافي من الكوارث للأنظمة الحرجة.	من الأنظمة 100% الحرجة	إدارة تقنية المعلومات + إدارة استمرارية الأعمال	الربع الثالث من السنة الأولى	مخطط
الاستعداد لشهادة ISO/IEC 27001:2022 5.	اختيار جهة اعتماد/شهادة مؤهلة لإجراء تدقيق الشهادة.	جهة واحدة معتمدة	مدير المشروع	الربع الرابع من السنة الأولى	مخطط
الاستعداد لشهادة ISO/IEC 27001:2022 5.	تنفيذ تدقيق ما قبل الشهادة ومعالجة الملاحظات الرئيسية قبل التدقيق الرسمي.	من الملاحظات الرئيسية 100%	استشاري خارجي + ISMS فريق	الربع الرابع من السنة الأولى	مخطط
الاستعداد لشهادة ISO/IEC 27001:2022 5.	اجتياز تدقيق الشهادة الرسمي لنظام إدارة أمن المعلومات.	اجتياز التدقيق	جهة إصدار الشهادة + ISMS فريق	الربع الرابع من السنة الأولى	مخطط
الاستعداد لشهادة ISO/IEC 27001:2022 5.	الحصول على شهادة ISO/IEC 27001:2022 والمحافظة على التحسين.	شهادة سارية	ISMS فريق	الربع الرابع من السنة الأولى وما بعده	هدف نهائي

				ISMS. المستمر لنظام	
--	--	--	--	---------------------	--

ربط الأهداف بدراسة الحالة

المصدر في دراسة الحالة	المشكلة/الحاجة	الهدف المرتبط
الحوادث السابقة	انقطاع الخدمات، التصيد، فقدان جهاز غير غير HR صلاحيات، TLS مشفر، انتهاء المصرح بها	إدارة الصلاحيات، MFA، رفع الوعي، التشفير، إدارة التهيئة والاستمرارية
الثغرات الحالية	ثغرات عالية في تطبيق آفاق بلس، إضافة 3 إلى ثغرات متوسطة ومنخفضة غير معالجة	إدارة الثغرات واختبارات الاختراق ومعالجة النتائج الحرجة
الوعي الأمني	نقروا على رابط التصيد، 12% أدخلوا 25% بياناتهم، و8% أبلغوا عن الرسالة	برنامج توعية واختبارات تصيد دورية وقياس التحسن
الحوكمة والتوثيق	مراجعات SIEM، ضعف التوثيق، عدم وجود امثال غير منتظمة، وسياسات قديمة/غير مكتملة	سياسات وإجراءات، سجل ISMS، إطار مخاطر، تدقيق داخلي وتحسين مستمر
الاستمرارية	وجود مركز تعافي من الكوارث وحاجة البنك لخدمات رقمية متاحة باستمرار	وتحسين جاهزية الأنظمة BCP/DR اختبار الحرجة
الامتثال	متطلبات ساما وسدايا وحماية بيانات العملاء	أهداف امثال وتدقيق داخلي وخطة إجراءات تصحيحية

اعتماد الوثيقة: تُراجع الأهداف دورياً من الإدارة العليا وفريق ISMS.

وتُقاس نتائجها باستخدام مؤشرات أداء موثقة، مع تحديثها عند تغير المخاطر أو نطاق ISMS أو المتطلبات القانونية والتنظيمية .